

Where the build stands against the three plans.

Foxy Audit is Governance-as-Code for AI apps — one decorator gives any LLM call a tamper-evident, privacy-preserving audit trail without storing raw prompts. This dossier reconciles the current codebase against all three planning documents, the reviewer's gap list, and the team's open issues — and marks what remains before production.

BUILD LEDGER · MAIN @ 2762FE6			● ANCHORING LIVE ON SEPOLIA
3 → 1 plan docs reconciled into one shipped system	8 / 10 reviewer gap items closed (2 deferred by design)	50 backend integration tests, green in CI	1 public-chain contract, live & independently verified

Feature ledger — planned, built, and what's left

Every capability, the plan(s) that called for it, its status in the code today, and the honest remaining work before a paying customer runs it unsupervised. ● DONE

shipped & verified ·

PARTIAL

 works, narrower than the pitch ·

DEFERRED

intentionally Phase 4.

CAPABILITY	CALLED FOR IN	STATUS	REMAINING FOR PRODUCTION
PRODUCT SURFACE – WHERE HUMANS ACTUALLY LOOK			
Web dashboard (browser, multi-seat) Home · Threats · Ledger · Verify · Policy · Keys · Export · Settings	Master Guide Review §2.1	DONE	Premium HTML served same-origin from FastAPI (no React/Tailwind). Left: per-tenant branding, mobile polish.
Desktop fox — ambient guard PyQt6 pixel-art mascot + tray	CipherTrail Master Guide	PARTIAL	Now a secondary "ambient" layer. Left: sprite-disappear bug (#6), Backend-URL/API-key settings fields (#8), Open-Dashboard menu (#2).
TRUST & CRYPTOGRAPHY – THE CORE CLAIM			
Sequential SHA-256 hash chain tamper-evident, one writer/verifier impl	All 3 plans	DONE	Core, golden-vector pinned in CI. Nothing outstanding.
Correct terminology "hash chain", not "Merkle Tree"	Review §2.3 · #4	DONE	Fixed across README, guide, dashboard labels.
Public-chain anchoring "trust the math, not the admin"	Master Guide §3.5 Review #5	DONE · LIVE	AnchorRegistry deployed & anchoring on Sepolia; verifier confirms on-chain root. Left: mainnet/L2 + funded-key ops for prod.
Independent verifier recompute vs on-chain root	Review	DONE	<code>verify_anchor.py</code> — anyone can re-prove a receipt.
Verification Sandbox / Verify page Core Requirement #3	REQ-3 issue #11	DONE	Live <code>GET /v1/verify</code> + browser sandbox; tamper flips it red.
Compliance passport (PDF/HTML) exportable proof for auditors	Master Guide	DONE	Cites the on-chain anchor tx. Left: e-signature / notarization if buyers ask.
DATA, PRIVACY & THE AI JUDGE			

CAPABILITY	CALLED FOR IN		STATUS	REMAINING FOR PRODUCTION
Zero-knowledge payload SDK hashes locally, discards raw text	REQ-2	Master Guide	DONE	foxy-audit SDK ships only hashes + metadata.
Active policy configuration Core Requirement #1	REQ-1	issue #10	DONE	Policy table + GET/PUT /v1/policies + dashboard toggles feeding the Gemini prompt.
Gemini AI judge grades metadata for policy/injection risk	Master Guide	Review #8	PARTIAL	Policy-aware, but still threshold-driven. Left: AI-native temporal reasoning (patterns over time) — Phase 4.
PII detection local signal flags	Review #9		PARTIAL	Email/SSN patterns only. Left: phone, cards, addresses, names, MRNs — Phase 4.
INGESTION DURABILITY & OPERATIONS				
Durable grading queue "nothing falls through the cracks"	Review #2	issue #9	DONE	Postgres-outbox poller (FOR UPDATE SKIP LOCKED) — no Redis, crash-safe. Replaces the demo-killer in-memory pool.
Docker deploy + secure defaults Dockerfile · compose · fail-fast secrets	Review #6		DONE	Migrate-gated compose, prod fail-fast on weak SESSION_SECRET / API_KEY_PEPPER , CORS locked. Left: managed hosting.
Health / readiness + worker heartbeat detects a stuck grader	hardening		DONE	/health/ready flips 503 when the worker goes stale.
CI + automated tests regression net for the trust claim	Review #7		DONE	50 Postgres integration tests + golden-chain + SDK, on every push. Left: broaden coverage over time.
Billing (Stripe) auto-provision org + key on checkout	Master Guide		PARTIAL	Webhook + provisioning done. Left: the self-serve signup page in front of it.
ACCESS MANAGEMENT & MULTI-TENANCY				
Human auth + RBAC admin vs member, per-user sessions	Review §2.2 · #3		DONE	bcrypt + signed-cookie sessions; cross-tenant login hardened. Left: SSO/SAML (below).

CAPABILITY	CALLED FOR IN	STATUS	REMAINING FOR PRODUCTION
HMAC-with-pepper API keys (multi-key) named keys, create/revoke	Review T1-4	● DONE	Peppered HMAC + legacy fallback; a DB leak can't recover keys.
Keys & Access page + user provisioning Core Requirement #5	REQ-5 issue #4	● DONE	List/create/revoke keys; invite/disable users — no longer curl-only.
Tenant isolation RLS + app-level org scoping	Master Guide	● DONE	Proven by dedicated cross-tenant tests.
SSO / SAML / MFA enterprise identity	CipherTrail (Clerk)	● DEFERRED	Phase 4 — table-stakes for large enterprise, not for a design-partner pilot.
ANALYTICS & ENTERPRISE ASSURANCE			
Threat Analytics Overview Core Requirement #6	REQ-6 issue #5 · #7	● DONE	/v1/analytics + Threats page (trend, breach counts, sparkline).
SOC 2 · data residency · uptime SLAs procurement gates	Review §4	● DEFERRED	Business + time + money, independent of code quality. Phase 4+.

02 · THE PRODUCT IN BRIEF

What Foxy Audit actually is

A developer-first compliance layer for AI. A startup adds one decorator to any LLM call and instantly gets a tamper-evident, privacy-preserving audit trail — the "Stripe for AI compliance" wedge — without ever handing Foxy their users' raw prompts.

It rests on four pillars, all present in the code today:

- **Governance-as-Code** — `@foxy.audit` turns months of compliance work into a `pip install` + a decorator.

- **Zero-Knowledge Payload** — the SDK hashes prompt/response locally and discards the raw text; only hashes + metadata leave the machine.
 - **Active-Defense AI Judge** — Gemini grades that metadata against the org's configured policy in real time.
 - **Sequential Hash Chain** — a Postgres-native ledger gives tamper-evidence at web-app speed, now **anchored to a public blockchain** so tampering is externally detectable — not just recomputable by us.
-

03 · RECONCILING THREE PLANNING DOCUMENTS

The three plans — and how the build compares

The project accreted across three documents written months apart. The current system is a deliberate synthesis: it keeps the strongest idea from each and overrides the parts that didn't survive contact with reality.

PLAN 1 · ORIGINAL ARCHITECTURE

CipherTrail Technical Architecture

v3.0 · Jun 2025 · old codename

The first engineering blueprint. Five-layer system with:

- Redis + Celery async queue
- Next.js 14 + Tailwind + Clerk frontend
- Railway + Vercel hosting
- "Merkle ledger" + ZKP tiers

BUILD VERDICT

Superseded on infra. We dropped Redis, Clerk, Next.js and Vercel — each replaced by a simpler, more durable choice below.

PLAN 2 · PRODUCT + GTM

Foxy Audit Master Guide

Jun 2026 · the definitive pitch

The refined four-pillar product and go-to-market bible. Correctly reframes the ledger as a **hash chain**, and — crucially — specifies **hybrid anchoring** (§3.5): publish the chain head to a public ledger periodically.

- Four pillars (all built)
- RLS tenant isolation
- Hybrid public-ledger anchor

BUILD VERDICT

Delivered — including the §3.5 anchor, now live on Sepolia. This is the plan the code follows.

Engineering & Business Review

the gap analysis + roadmap

A line-level audit of the skeleton vs. the pitch. Confirmed most blockers were already fixed, then named what was genuinely missing and ranked it (\$3), with an ordered roadmap (\$8).

- 10-item severity ranking
- "What to do next, in order"

BUILD VERDICT

Executed. \$8's week-1 / 2–4-week / parallel roadmap is done — see the gap ledger below.

Where the build deliberately diverged from the plans

DIMENSION	WHAT THE PLANS SAID	WHAT WE BUILT (& WHY)
Web front-end	Next.js 14 + Tailwind + Clerk, on Vercel (CipherTrail / Master Guide)	Premium hand-built HTML served same-origin from FastAPI , custom bcrypt sessions. No React/Tailwind/Clerk — fewer moving parts, one deploy, no BFF/CORS dance.
Async queue	Redis + Celery (CipherTrail) — which shipped as an undeclared dep and silently dropped logs (issue #9)	Durable Postgres outbox — the job lives in the same row as the chain data, so a crash can't lose it. No Redis to run.
Ledger name	"Merkle Tree" / "PostgreSQL Merkle Chain" (both docs — a misnomer)	Called what it is: a sequential hash chain . Same tamper-evidence, honest naming that survives a security judge.
On-chain	CipherTrail: none (ZKP tiers). Master Guide §3.5: hybrid anchor. Review #5: missing .	Live public-blockchain anchoring — pluggable provider, deployed to Sepolia, independently verifiable. The headline "trust the math" proof.
Identity	Clerk (SSO/MFA) (CipherTrail / Master Guide)	Custom bcrypt sessions + admin/member RBAC. SSO/SAML deferred to Phase 4 — right-sized for a pilot.
Hosting	Railway (backend + Redis + PG) + Vercel (CipherTrail)	Portable Docker Compose (db · migrate · backend · worker · seed) — runs anywhere, prod-secret fail-fast built in.

The Review's 10-item gap ledger → status now

Section 3 of the Engineering Review ranked exactly what was left, by severity. Eight are shipped; the two remaining were explicitly scoped out to Phase 4 (deeper AI, broader PII) — not blockers for a design-partner pilot.

#	GAP THE REVIEWER FOUND	SEVERITY (THEIRS)	STATUS	HOW IT WAS CLOSED
1	No real web dashboard (Next.js claimed, didn't exist)	Critical · sales	DONE	Premium web dashboard served from FastAPI; the desktop fox became the ambient layer.
2	No durable task queue (in-memory ThreadPool → silent loss)	Critical · trust	DONE	Durable Postgres-outbox poller, crash-safe.
3	No human auth/RBAC, only an org-wide API key	Critical · enterprise	DONE	bcrypt sessions, admin/member roles, per-user provisioning.
4	"Merkle Tree" / "zero-knowledge" terminology overclaim	High · credibility	DONE	Renamed to "hash chain" everywhere; claims corrected.
5	No external anchoring of the chain head	High · core USP	LIVE	Public-chain anchoring, deployed & verified on Sepolia.
6	weasyprint native-dependency deploy risk	Medium	DONE	Lazy import + HTML fallback; Dockerfile installs the native libs; container built in CI.
7	No CI / automated tests despite real test files	Medium-high	DONE	50 Postgres integration tests + golden-chain + SDK, gated in GitHub Actions.
8	Gemini judge mostly re-implements hardcoded thresholds	Medium	DEFERRED	Made policy-aware now; AI-native temporal reasoning is Phase 4.
9	PII regex only catches email/SSN	Medium	DEFERRED	Kept as an honest "signal flagger"; broader PII is Phase 4.
10	Single org per desktop install, no multi-seat	Medium	DONE	Multi-seat web dashboard + multi-key + RBAC.

The Review's own roadmap (\$8), executed

Week 1 (terminology · weasyprint · CI), the 2–4-week block (web dashboard · human auth · durable queue), and the "in parallel" items (external anchoring · HMAC-with-pepper keys · a Keys & Access page) are all shipped. What the review framed as "demo-credible → buyer-credible" is done.

05 · PROBLEMS RAISED BY THE TEAM ON GITHUB

The teammate's open issues → status

The 12 issues on the repo (mostly filed by @fatimaatta-09) map to Core Requirements #1–#6 and a set of desktop-app bugs. The backend/dashboard/requirement gaps are closed; what remains is desktop-app polish — now a secondary surface since the web dashboard is the real product.

ISSUE	PROBLEM RAISED	STATUS	WHERE IT LANDED
#9	[Demo killer] Celery/Redis undeclared dep — logs never reach the DB without Redis	DONE	Postgres-outbox queue (no Redis)
#10	[REQ-1] Active Policy Configuration — no UI, no table, no Gemini enforcement	DONE	Policy table + API + dashboard + judge
#11	[REQ-3] Verification Sandbox ("Trust the Math") does not exist	DONE	Verify page + on-chain anchor
#3	<code>GET /v1/logs</code> returns nothing — dashboard Refresh is dead	DONE	Paginated, RLS-scoped endpoint + web dashboard
#4	[REQ-5] No tenant management UI — can't revoke a stolen laptop	DONE	Keys & Access page + revoke
#5	[REQ-6] Threat Analytics Overview is missing	DONE	Threats page + sparkline
#7	Add <code>/v1/analytics</code> endpoint for the threat overview	DONE	analytics router (GROUP BY tag/hour)

ISSUE	PROBLEM RAISED	STATUS	WHERE IT LANDED
#1	Dashboard 'Refresh' button emits a signal nobody listens to (desktop)	● DESKTOP	Superseded by the web dashboard; desktop fix optional
#2	Desktop app has no way to open the dashboard — no menu/tray item (desktop)	● DESKTOP	Web dashboard is a URL now; add tray link if kept
#6	Fox sprite disappears on some setups (translucency bug) (desktop)	● OPEN	Desktop polish — the demo mascot
#8	Settings dialog needs Backend-URL + Org-API-Key fields (desktop)	● OPEN	Desktop config — lower priority than web
#14	Quickdraw test issue (noise)	● CLOSED	—

06 · THE ROAD TO PRODUCTION

What's genuinely left

Phases 1–3 are shipped to **main** and the anchoring pilot is live. What remains splits cleanly into product depth, enterprise gates, ops, and desktop polish — none of which block a friendly design-partner pilot.

Product depth — Phase 4

- **AI-native Gemini** — feed sequences of events so the judge reasons about patterns over time, not fixed thresholds (Review #8).
- **Real PII detection** — beyond email/SSN: phone, cards, addresses, names, medical record numbers (Review #9).
- **Self-serve signup** — the Stripe webhook already provisions orgs; it needs a signup page in front of it.

Enterprise gates

- **SSO / SAML / MFA** — table stakes for large security buyers.
- **SOC 2, data residency, uptime SLAs, incident response** — months + real money, independent of code quality.
- **Contractual notarization** of the passport if buyers demand it.

On-chain, for production

- **Mainnet or an L2** instead of Sepolia testnet, with a funded operational wallet + key management.
- **Anchor monitoring** — alerting if the periodic anchor fails or a receipt goes stale.
- **Cadence/cost tuning** per tenant (anchor interval vs gas).

Desktop app polish

- **Sprite-disappear bug (#6)** — the demo mascot must render everywhere.
- **Settings fields (#8) + Open-Dashboard tray link (#2)** if the fox stays in the story.
- Otherwise: keep it as a pure ambient-guard notifier.

Bottom line

The reviewer's own framing was: a strong prototype "wearing a UI that doesn't match its own sales pitch." That gap is closed. The product now **does the thing on its headline promise** — a real web dashboard, durable ingestion, human auth, and a tamper-evident chain whose head is anchored to a public blockchain and independently verifiable. What's left is depth and enterprise assurance, not credibility.

FOXY AUDIT · STATUS DOSSIER · reflects `main` @ 2762fe6 · sources: CipherTrail Architecture v3.0, Foxy Audit Master Guide, Engineering & Business Review PDF, GitHub issues #1-#16.

● DONE – SHIPPED & VERIFIED

● LIVE ON-CHAIN

● PARTIAL – NARROWER THAN PITCHED

● DEFERRED – PHASE 4 BY DESIGN